

CYBERSECURITY LAB REPORT

Windows Password Bypass via WinRE & Utilman.exe Exploitation

Attack Execution, Detection via Wazuh SIEM & Remediation

Experiment Type: Offensive Security / Privilege Escalation

Target OS: Windows 10 / Windows 11

Attack Vector: Physical Access + WinRE CMD (Pre-Authentication)

Tools Used: WinRE, CMD.exe, control userpasswords2, Wazuh SIEM

MITRE ATT&CK Technique: T1546.008 — Accessibility Features

Risk Level: 🚨 CRITICAL

Report Date: 06 August 2026

Classification: Educational / Authorized Lab Use Only

⚠️FOR EDUCATIONAL AND AUTHORIZED TESTING PURPOSES ONLY⚠️

1. Executive Summary

This report documents a critical Windows security vulnerability that allows an attacker with physical access to bypass the login screen entirely — without knowing any user credentials — by exploiting the Windows Recovery Environment (WinRE) and the Accessibility Features (Ease of Access) mechanism on the lock screen.

The attack replaces the legitimate accessibility binary (utilman.exe) with cmd.exe in the System32 directory using WinRE's command prompt — which runs at SYSTEM-level privilege before any user authenticates. Once rebooted into Windows, clicking the Ease of Access button on the lock screen spawns a SYSTEM-level command prompt, enabling full account takeover.

The report also covers detection using Wazuh SIEM, and the steps required to restore the system and harden it against this attack.

MITRE ATT&CK Maps this to T1546.008 (Event Triggered Execution: Accessibility Features). This is a well-known persistence and privilege escalation technique used in real-world red team engagements and APT campaigns.

2. Vulnerability Background

2.1 What is utilman.exe?

utilman.exe (Utility Manager) is the Windows Ease of Access executable, launched when a user clicks the Accessibility icon on the Windows login/lock screen. It runs BEFORE any user is authenticated, which means it runs in SYSTEM context — the highest privilege level in Windows.

Location: C:\Windows\System32\utilman.exe

Because it executes pre-authentication in SYSTEM context, replacing it with any shell or binary gives an attacker unrestricted SYSTEM-level access without credentials.

2.2 What is WinRE?

Windows Recovery Environment (WinRE) is a minimal Windows environment that boots from a dedicated partition. Its Command Prompt runs outside the normal OS context, meaning:

- It bypasses Windows login requirements
- It bypasses NTFS permission enforcement in many cases
- It has access to the main Windows partition filesystem
- It can rename / replace system files like utilman.exe

2.3 How this Works

The attack exploits the intersection of two design decisions:

- WinRE CMD runs with elevated permissions to allow system repairs
- utilman.exe is called pre-authentication at SYSTEM privilege

Combining these two gives an attacker a clean path: modify the system in WinRE → trigger the modification from the lock screen → get SYSTEM shell → reset any password.

2.4 MITRE ATT&CK Reference

Technique ID: T1546.008

Tactic: Persistence, Privilege Escalation

Sub-technique: Event Triggered Execution: Accessibility Features

Platform: Windows

Required Access for Setup: Physical Access + WinRE (no credentials needed on unencrypted drives)

Result: SYSTEM-level shell pre-authentication → Full account takeover

3. Lab Prerequisites & Setup

3.1 Requirements

- A Windows 10 or Windows 11 machine (physical or VM)
- Physical access OR VMware/VirtualBox console access
- BitLocker must be DISABLED (encrypted drives block WinRE write access)
- Wazuh SIEM (for detection phase)
- Authorized environment only — personal lab or test VM

3.2 Understand Before You Begin

This attack WILL NOT work if BitLocker drive encryption is enabled. WinRE can access the drive but Windows will block modifications to encrypted volumes. This is why BitLocker is a core defense against this attack.

Important file locations involved:

```
C:\Windows\System32\utilman.exe → Target binary (Ease of Access)
C:\Windows\System32\cmd.exe      → Payload (Command Prompt)
C:\Windows\System32\utilman1.exe → Our backup of the original utilman
```

4. Attack Walkthrough — Step by Step

Step 1: Boot into Windows Recovery Environment (WinRE)

Hold Shift and click Restart from the Windows Start menu or sign-in screen. The system will boot into the WinRE environment instead of the normal OS.

Alternatively, on physical machines you can force WinRE by interrupting the boot process 2–3 times (e.g., holding the power button during startup). Many OEMs also provide a boot menu key (F12, F8, F2 etc.).

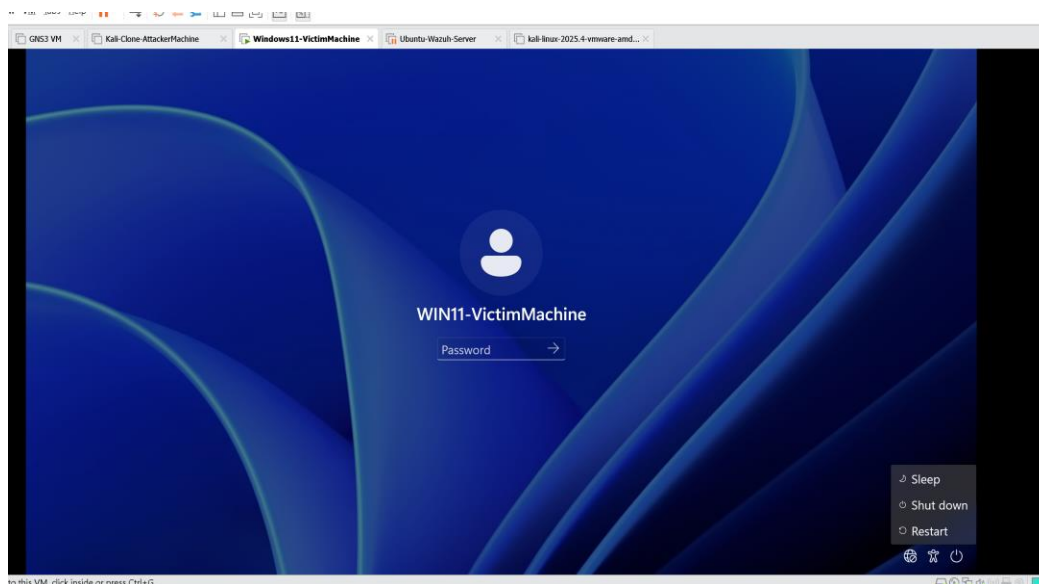


Figure 1 – Shift + Restart to enter Windows Recovery Environment

Step 2: Navigate to Troubleshoot

From the blue recovery screen, click Troubleshoot.

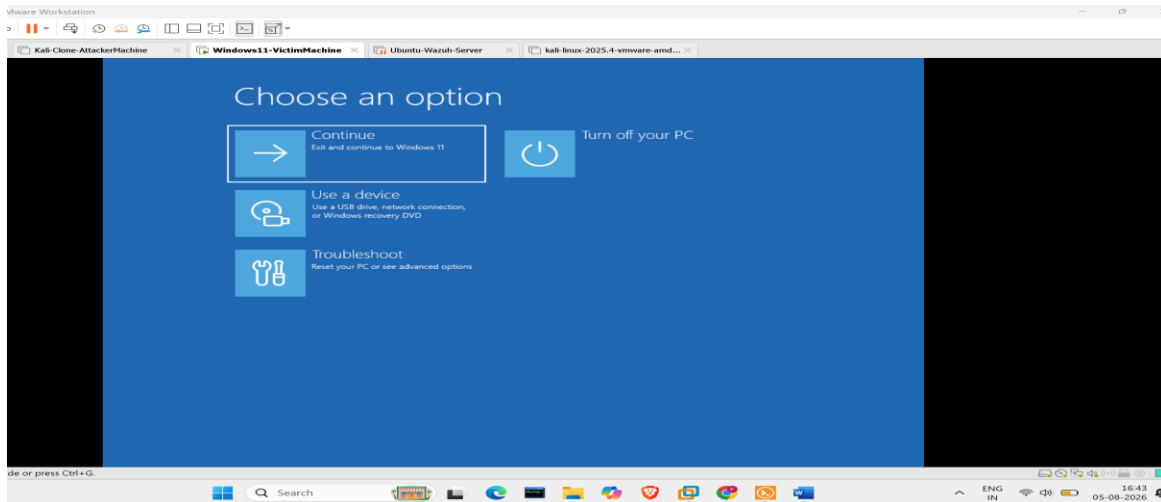


Figure 2 – Choose Your Option screen → Select Troubleshoot

Step 3: Open Advanced Options

Inside Troubleshoot, select Advanced options to access system-level recovery tools.

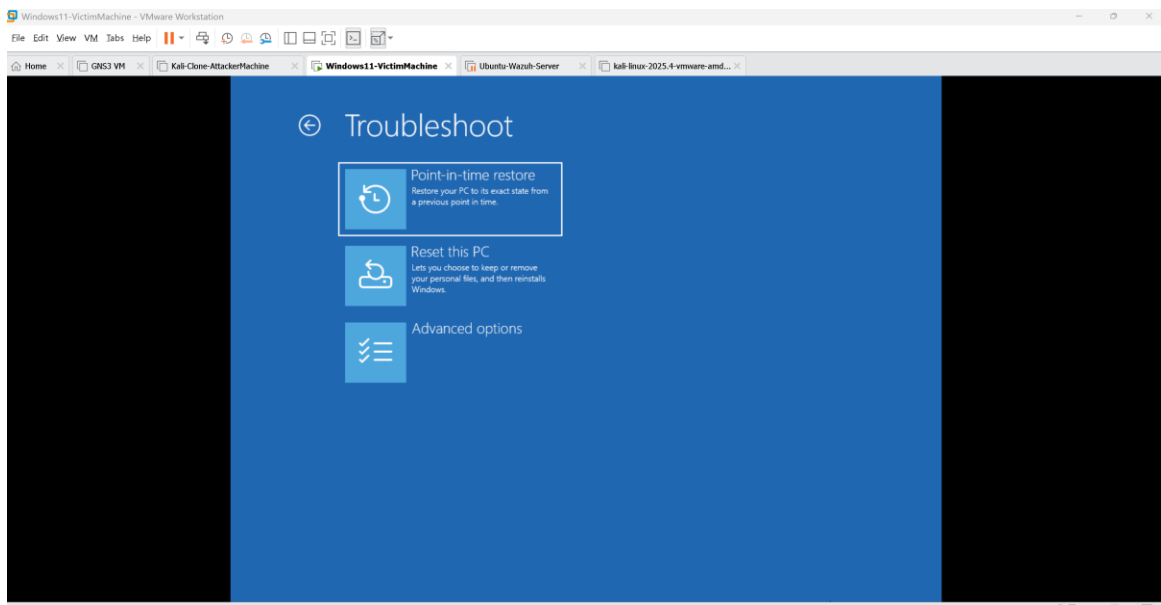


Figure 3 – Advanced Options menu in WinRE

Step 4: Open Command Prompt in WinRE

Click Command Prompt. If prompted, select your Windows installation. The CMD that opens here runs at SYSTEM privilege on the recovery partition.

You may be asked to choose a recovery account and enter its password — on many home/lab systems no password is set. On domain machines, you need local admin credentials for the WinRE CMD.

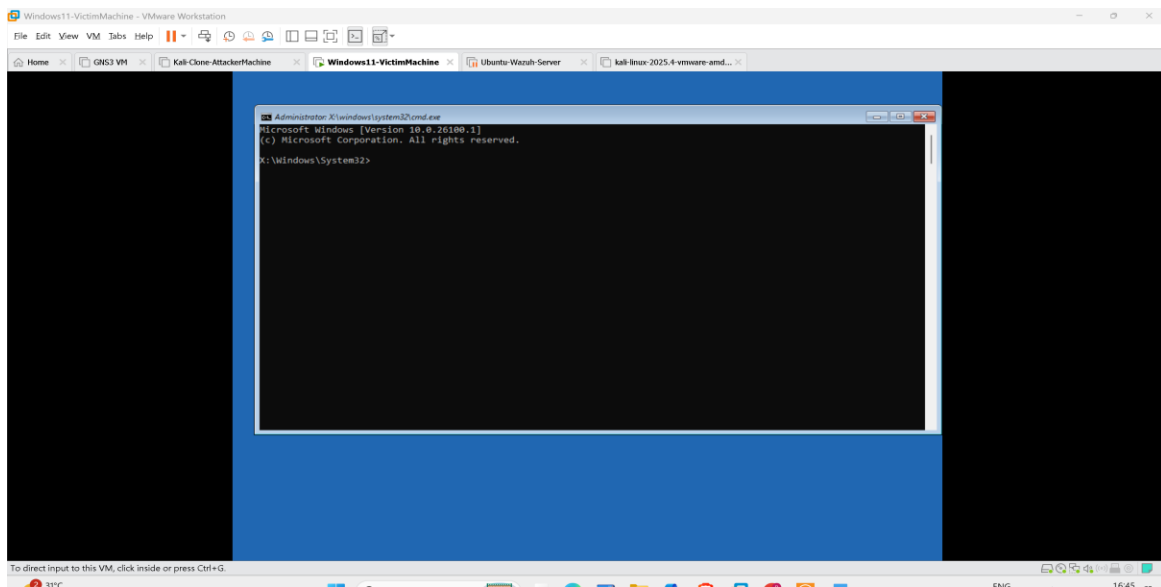


Figure 4 – Launching Command Prompt from WinRE Advanced Options

Step 5: Identify the Windows Drive Letter

Inside WinRE, drive letters may differ from the normal Windows session. The main Windows partition is often D: or C: in WinRE.

```
dir C:\
dir D:\
```

Check which drive shows the Windows, Users, and Program Files folders — that's your target drive.

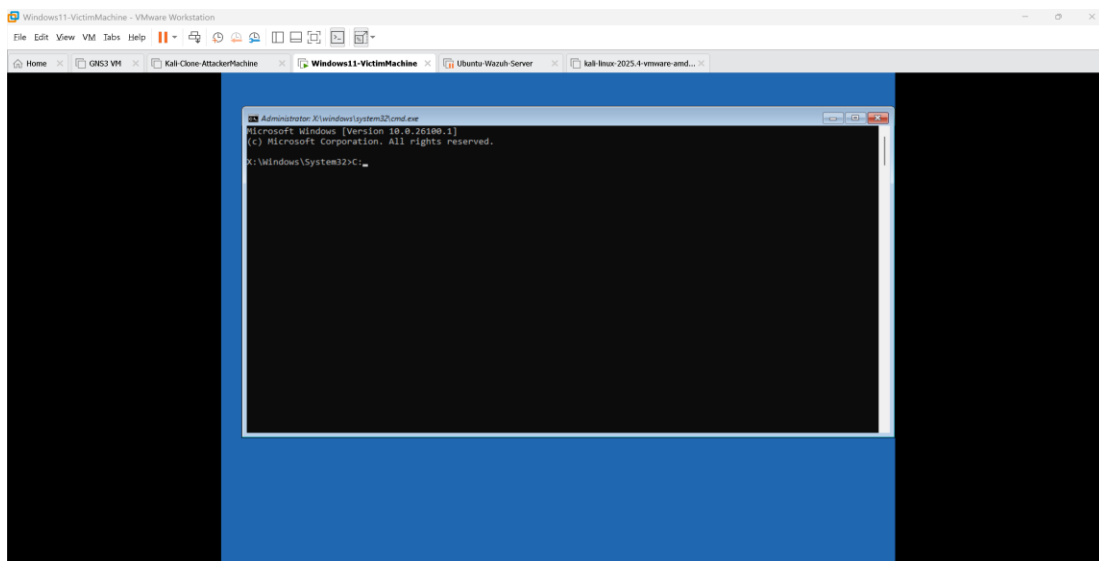


Figure 5 – Checking drive letters in WinRE CMD

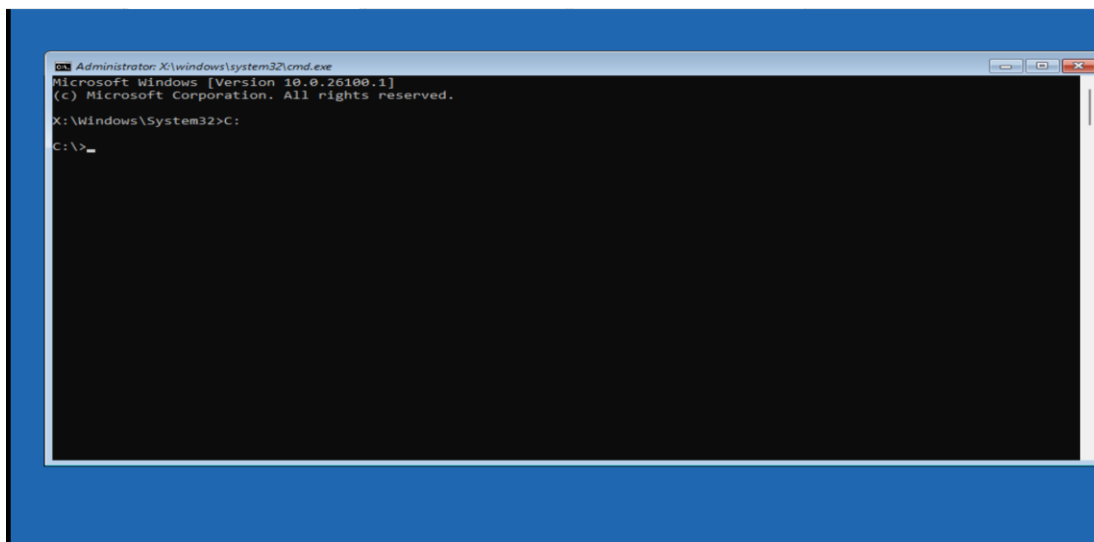


Figure 6 – Identifying the correct Windows drive

Step 6: Navigate to System32

Once you know the correct drive letter (assume C: here), navigate to System32:

```
C:
cd Windows
cd System32
```

You should now be at: C:\Windows\System32

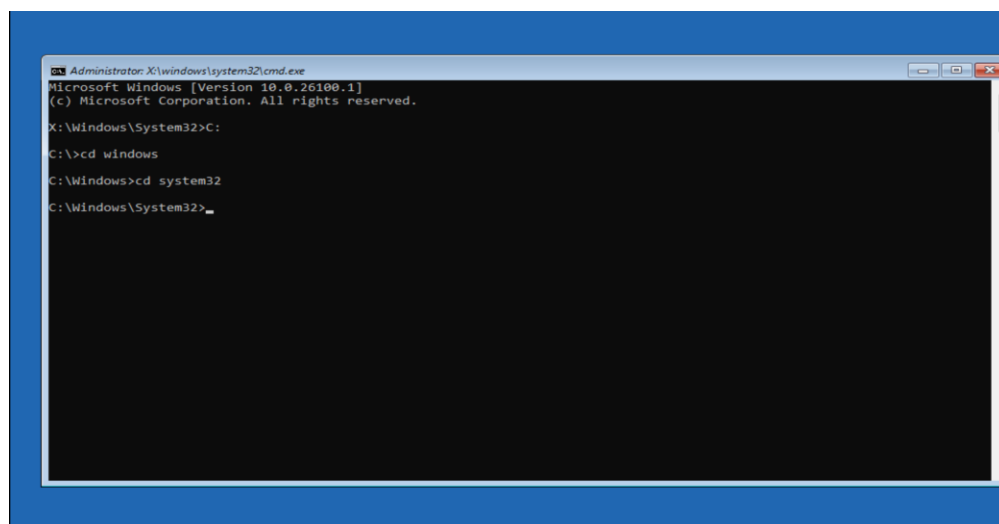


Figure 7 – Navigating to C:\Windows\System32

Step 7: Back Up the Original utilman.exe

Before replacing it, rename the original utilman.exe to preserve it for restoration:

```
ren utilman.exe utilman1.exe
```

IMPORTANT: Always back up before replacing. If you skip this, you won't be able to restore the system properly.

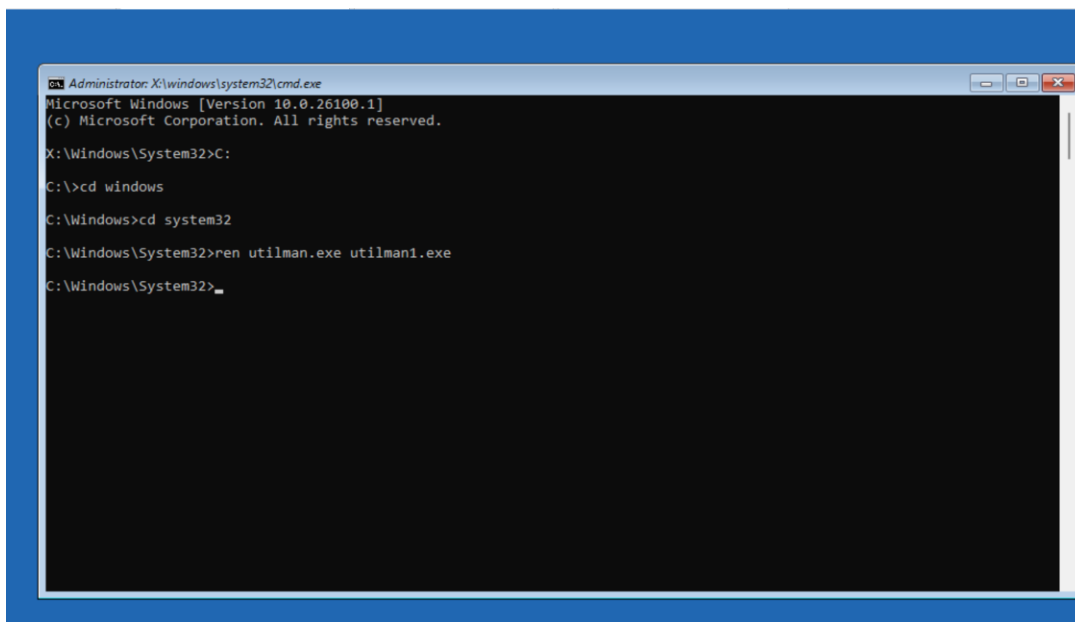


Figure 8 – Renaming utilman.exe to utilman1.exe as backup

Step 8: Replace utilman.exe with cmd.exe

Now copy cmd.exe and rename it as utilman.exe. We use copy instead of rename to keep cmd.exe intact:

```
ren cmd.exe utilman.exe  
copy cmd.exe utilman.exe
```

(Alternatively: ren cmd.exe utilman.exe — but this removes cmd.exe from System32, which can cause issues. Using copy is safer in lab environments.)

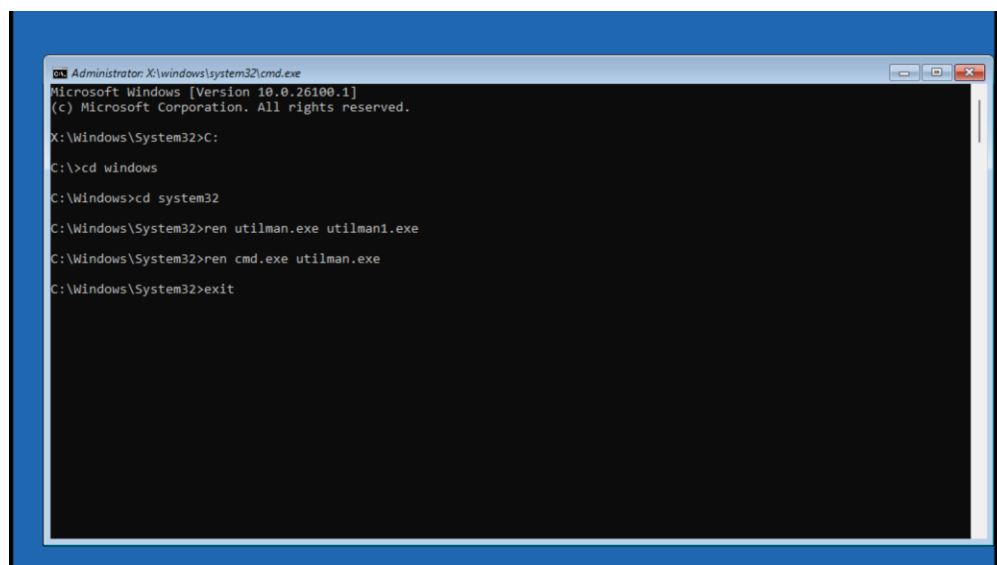


Figure 9 – Replacing utilman.exe with cmd.exe

Now type exit and close the WinRE CMD.

Step 9: Boot Back into Windows

From the WinRE screen, click Continue — Exit and continue to Windows. The system will reboot into the normal Windows login screen.

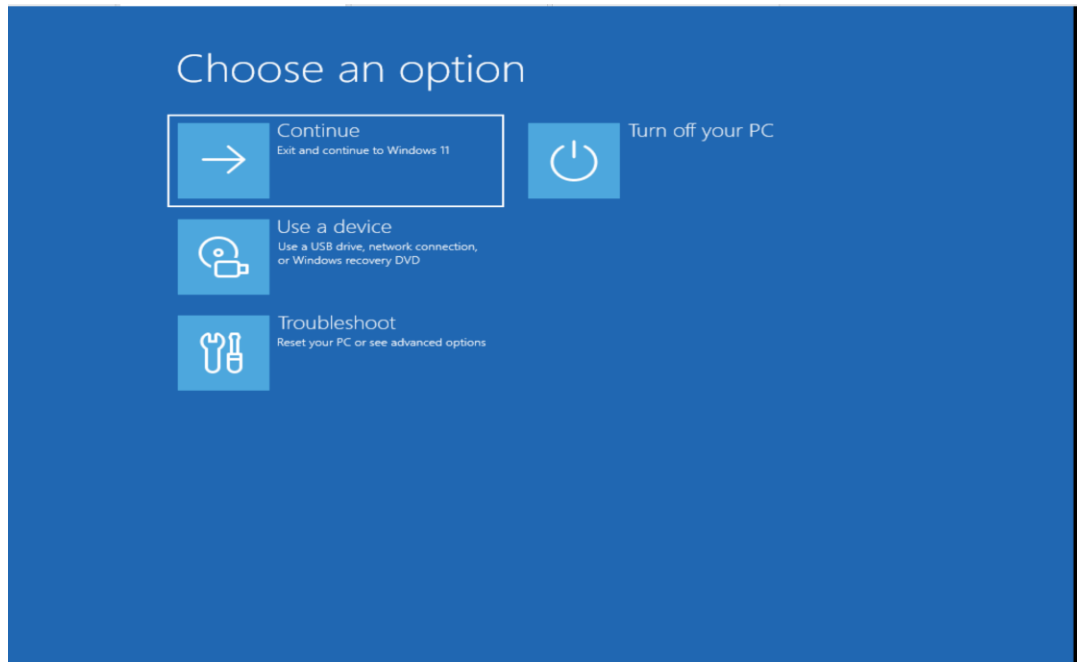


Figure 10 – Continue to reboot into normal Windows

Step 10: Trigger the Backdoor from the Login Screen

On the Windows login screen (where you are NOT yet authenticated), click the Accessibility / Ease of Access icon (bottom-right corner). Instead of opening the accessibility menu, cmd.exe (now masquerading as utilman.exe) will launch.

This CMD window runs as SYSTEM — the highest privilege on Windows. You have full control of the machine WITHOUT entering any password.

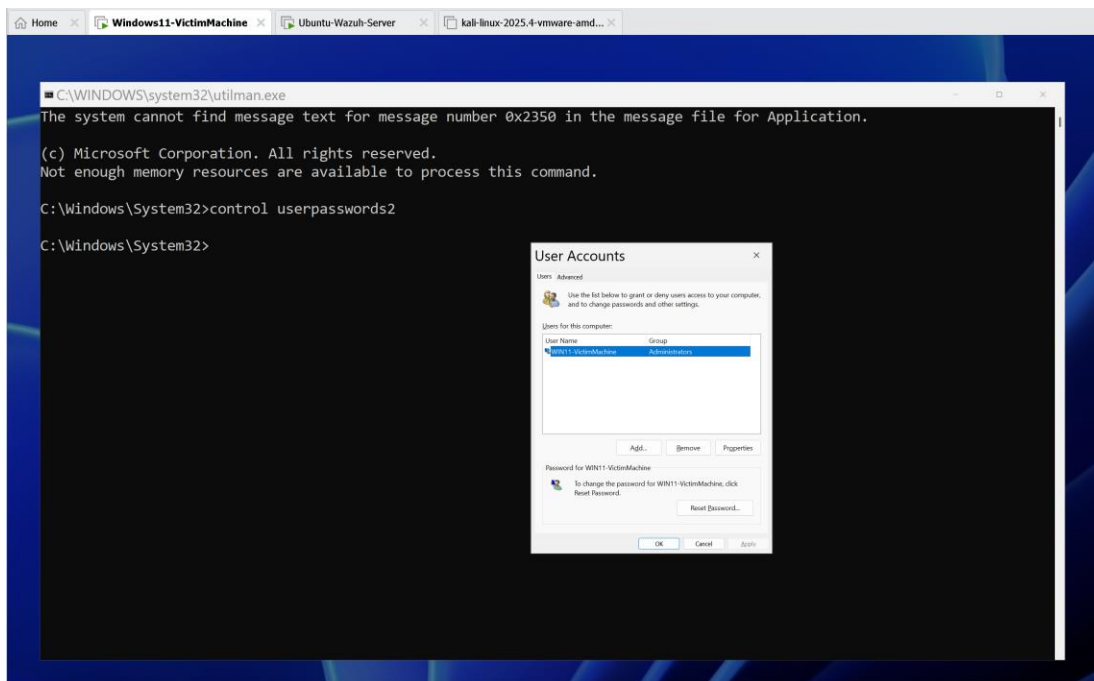


Figure 11 – Clicking Ease of Access icon on the lock screen

Step 11: Open User Account Control Panel

In the SYSTEM-level CMD that appeared, run:

```
control userpasswords2
```

This opens the classic User Accounts control panel, which allows password management for all local accounts.

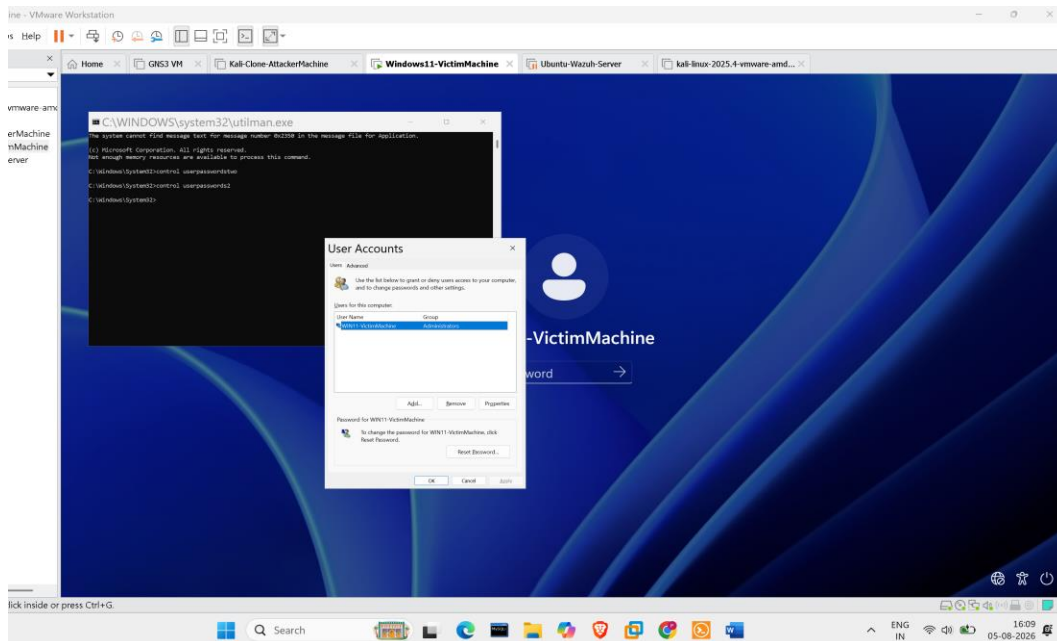


Figure 12 – SYSTEM CMD running control userpasswords2

Step 12: Select Account & Reset Password

In the User Accounts window, select the account whose password you want to reset, then click Reset Password.

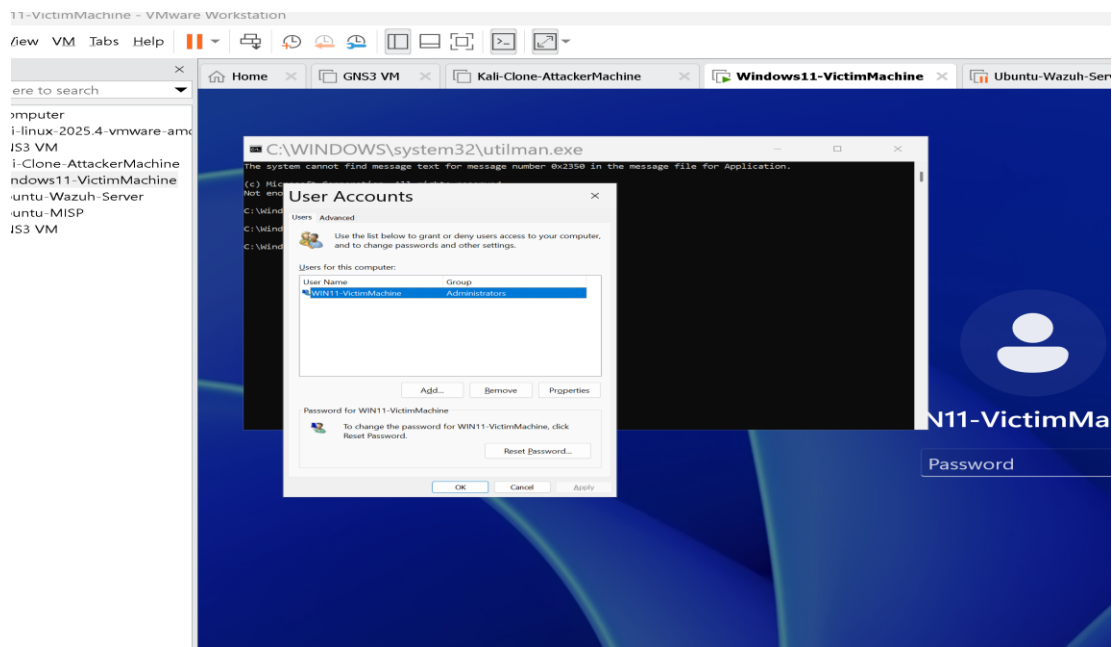


Figure 13 – User Accounts panel showing available accounts

Step 13: Set the New Password

Enter a new password and confirm it. Click OK. The password is now changed without knowing the original password.

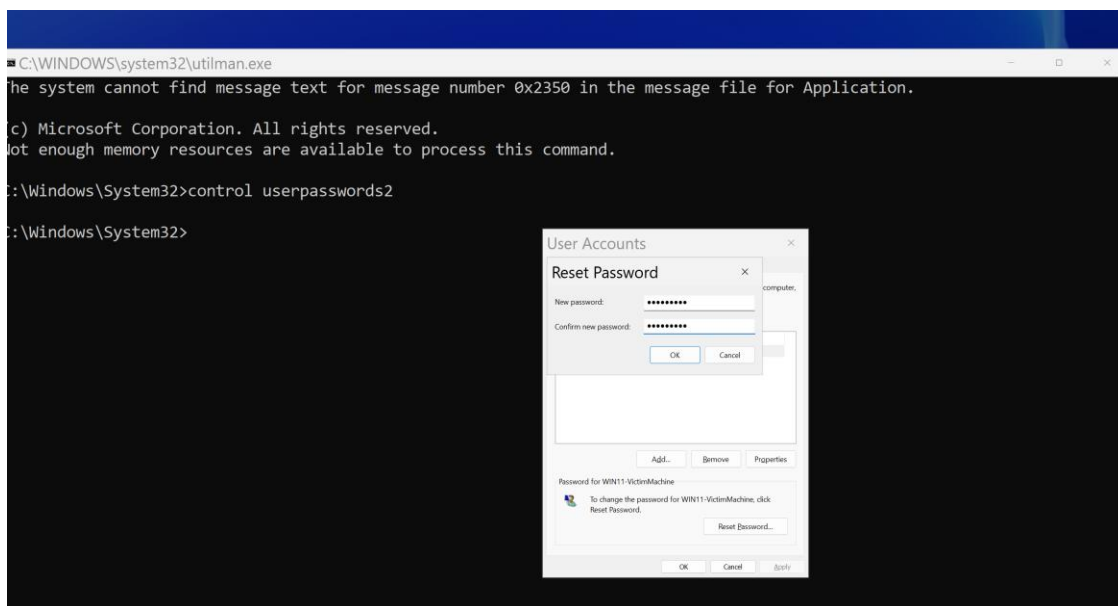


Figure 14 – Setting the new password for the selected account

Step 14: Advanced User Management via Local Users and Groups

From the Advanced tab in User Accounts → click Advanced → this opens lusrmgr.msc (Local Users and Groups). From here you can:

- Create brand new user accounts
- Add users to the Administrators group
- Unlock or enable the built-in Administrator account
- Disable accounts or change account properties

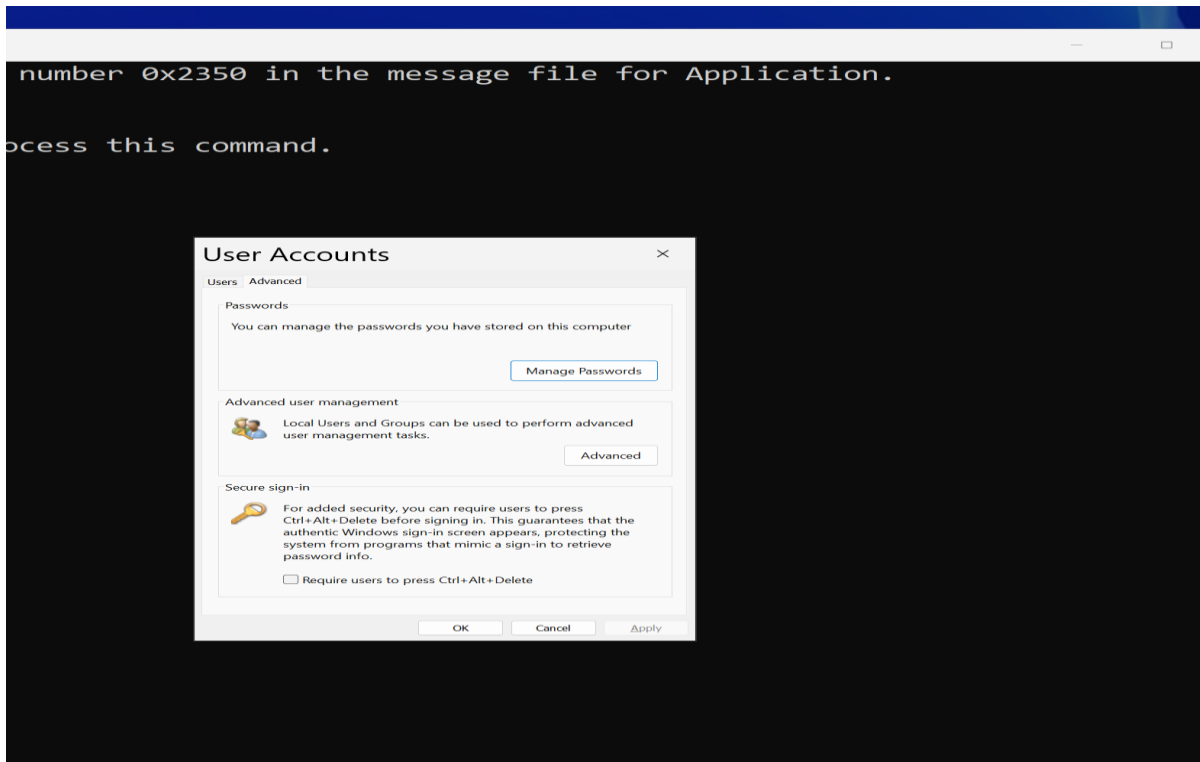


Figure 15 – Advanced tab in User Accounts

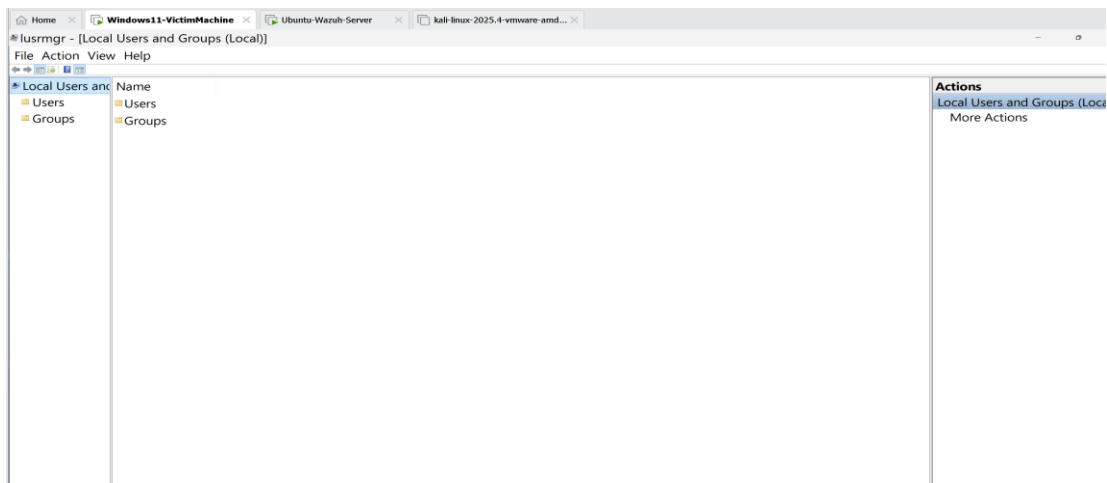


Figure 16 – Local Users and Groups management console (lusrmgr.msc)

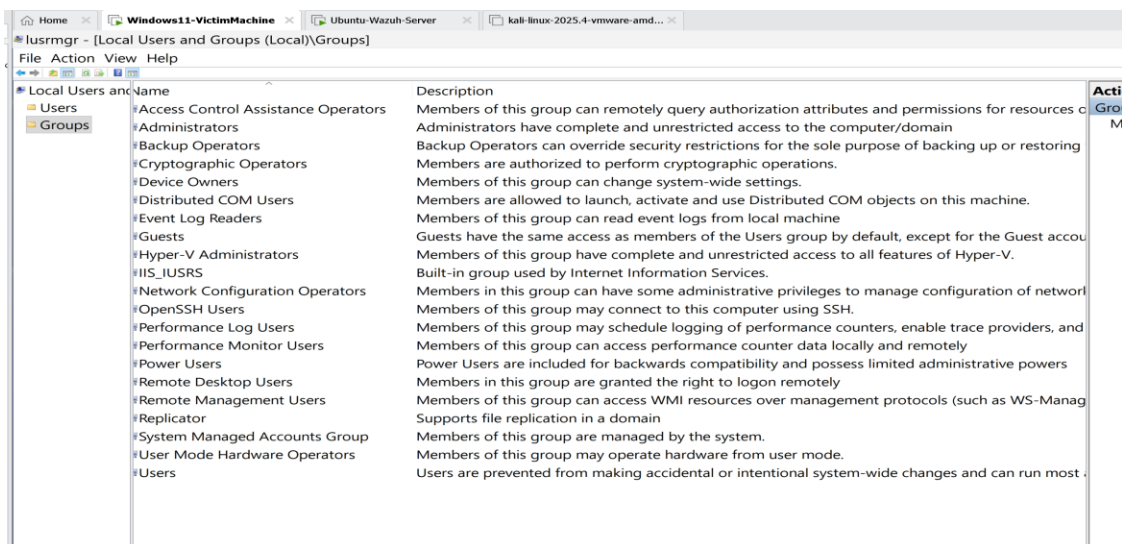


Figure 17 – User accounts listed in Local Users and Groups

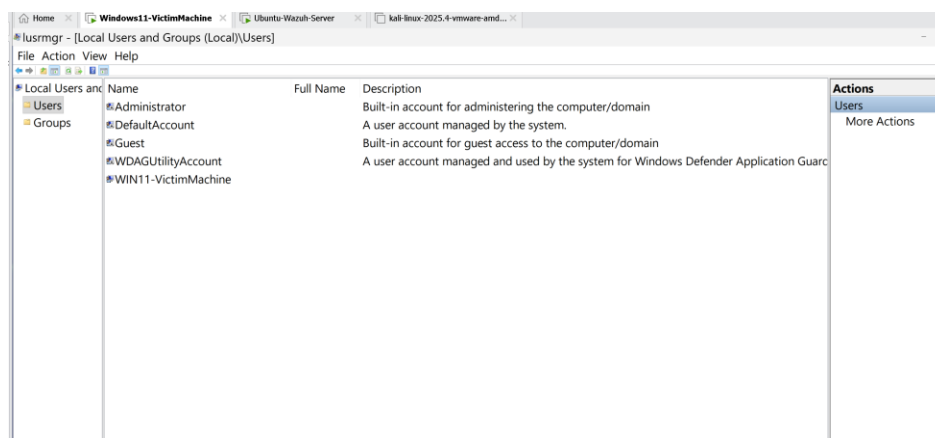


Figure 18 – Group memberships and Administrators group

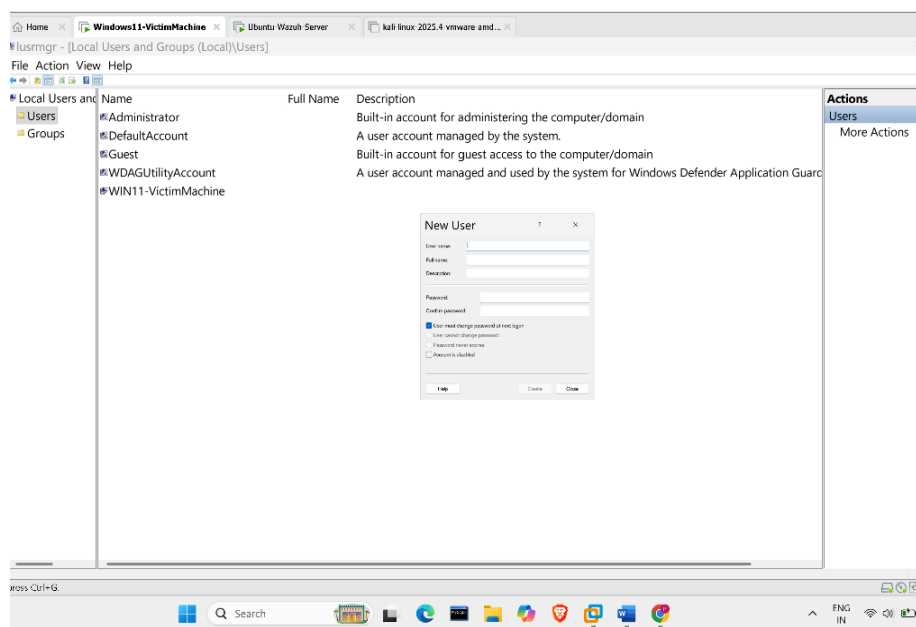


Figure 19 – Account properties and password options

At this point the attacker has full control: they can reset passwords, create backdoor admin accounts, extract credentials, or install malware — all from the lock screen.

5. Detection via Wazuh SIEM

5.1 What is Wazuh?

Wazuh is an open-source Security Information and Event Management (SIEM) and Extended Detection and Response (XDR) platform. It collects, correlates, and analyzes security events from endpoints, helping detect attacks like the utilman.exe replacement in real time or during forensic investigation.

5.2 What Events This Attack Generates

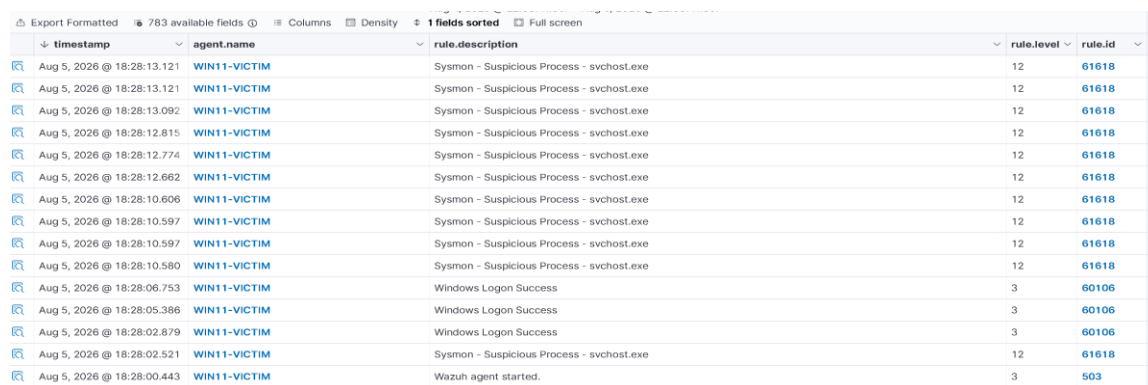
The utilman.exe replacement generates several detectable Windows Security Event Log entries:

Event ID	Event Name	Why It's Relevant
4663	File Access Attempt	Access to utilman.exe or cmd.exe in System32
4670	Permissions Changed on File	Modification of system binary permissions
4656	Object Handle Requested	Handle opened for utilman.exe before rename
4688	New Process Created	cmd.exe spawned as utilman.exe (parent: winlogon.exe)
4732	User Added to Privileged Group	If attacker adds a new admin account via lusrmgr

The most critical alert is Event 4688: cmd.exe (or suspicious binary) launched with parent process winlogon.exe from the lock screen. Wazuh can detect this with built-in Windows rules.

5.3 Wazuh Dashboard — Attack Detection

The Wazuh dashboard shows security alerts generated by the agent installed on the Windows target machine. After performing the utilman.exe replacement and triggering it on the lock screen, Wazuh logs correlated alerts:



timestamp	agent.name	rule.description	rule.level	rule.id
Aug 5, 2026 @ 18:28:13.121	WIN11-VICTIM	Sysmon - Suspicious Process - svchost.exe	12	61618
Aug 5, 2026 @ 18:28:13.121	WIN11-VICTIM	Sysmon - Suspicious Process - svchost.exe	12	61618
Aug 5, 2026 @ 18:28:13.092	WIN11-VICTIM	Sysmon - Suspicious Process - svchost.exe	12	61618
Aug 5, 2026 @ 18:28:12.815	WIN11-VICTIM	Sysmon - Suspicious Process - svchost.exe	12	61618
Aug 5, 2026 @ 18:28:12.774	WIN11-VICTIM	Sysmon - Suspicious Process - svchost.exe	12	61618
Aug 5, 2026 @ 18:28:12.662	WIN11-VICTIM	Sysmon - Suspicious Process - svchost.exe	12	61618
Aug 5, 2026 @ 18:28:10.606	WIN11-VICTIM	Sysmon - Suspicious Process - svchost.exe	12	61618
Aug 5, 2026 @ 18:28:10.597	WIN11-VICTIM	Sysmon - Suspicious Process - svchost.exe	12	61618
Aug 5, 2026 @ 18:28:10.597	WIN11-VICTIM	Sysmon - Suspicious Process - svchost.exe	12	61618
Aug 5, 2026 @ 18:28:10.580	WIN11-VICTIM	Sysmon - Suspicious Process - svchost.exe	12	61618
Aug 5, 2026 @ 18:28:06.753	WIN11-VICTIM	Windows Logon Success	3	60106
Aug 5, 2026 @ 18:28:05.386	WIN11-VICTIM	Windows Logon Success	3	60106
Aug 5, 2026 @ 18:28:02.879	WIN11-VICTIM	Windows Logon Success	3	60106
Aug 5, 2026 @ 18:28:02.521	WIN11-VICTIM	Sysmon - Suspicious Process - svchost.exe	12	61618
Aug 5, 2026 @ 18:28:00.443	WIN11-VICTIM	Wazuh agent started.	3	503

Figure 20 – Wazuh Dashboard overview showing security alerts

Aug 4, 2026 @ 22:08:41.857 - Aug 5, 2026 @ 22:08:41.857					
1 fields sorted					
timestamp	agent.name	rule.description	rule.level	rule.id	
Aug 5, 2026 @ 17:56:54.570	WIN11-VICTIM	Windows Logon Success	3	60106	
Aug 5, 2026 @ 17:56:54.462	WIN11-VICTIM	Process loaded taskschd.dll module. May be used to create delayed malware execution	4	92154	
Aug 5, 2026 @ 17:56:54.459	WIN11-VICTIM	Process loaded taskschd.dll module. May be used to create delayed malware execution	4	92154	
Aug 5, 2026 @ 17:56:33.033	WIN11-VICTIM	Process loaded taskschd.dll module. May be used to create delayed malware execution	4	92154	
Aug 5, 2026 @ 17:56:05.115	WIN11-VICTIM	SCA summary: CIS Microsoft Windows 11 Enterprise Benchmark v3.0.0: Score less than 30% (25)	9	19005	
Aug 5, 2026 @ 17:55:53.184	WIN11-VICTIM	CIS Microsoft Windows 11 Enterprise Benchmark v3.0.0: Ensure 'MSS: (AutoAdminLogon) Enable Automatic Log...	9	19011	
Aug 5, 2026 @ 17:55:52.861	WIN11-VICTIM	CIS Microsoft Windows 11 Enterprise Benchmark v3.0.0: Ensure 'Audit Other Policy Change Events' is set to inclu...	9	19014	
Aug 5, 2026 @ 17:55:50.298	WIN11-VICTIM	CIS Microsoft Windows 11 Enterprise Benchmark v3.0.0: Ensure 'Minimum password age' is set to '1 or more day...	9	19014	
Aug 5, 2026 @ 17:55:50.295	WIN11-VICTIM	CIS Microsoft Windows 11 Enterprise Benchmark v3.0.0: Ensure 'Maximum password age' is set to '365 or fewer ...	3	19015	
Aug 5, 2026 @ 17:55:40.595	WIN11-VICTIM	A net.exe account discovery command was initiated	3	92039	
Aug 5, 2026 @ 17:55:40.546	WIN11-VICTIM	A net.exe account discovery command was initiated	3	92039	
Aug 5, 2026 @ 17:55:40.531	WIN11-VICTIM	A net.exe account discovery command was initiated	3	92039	
Aug 5, 2026 @ 17:55:40.521	WIN11-VICTIM	A net.exe account discovery command was initiated	3	92039	
Aug 5, 2026 @ 17:55:39.608	WIN11-VICTIM	A net.exe account discovery command was initiated	3	92039	
Aug 5, 2026 @ 17:55:39.559	WIN11-VICTIM	A net.exe account discovery command was initiated	3	92039	

Figure 21 – Alert events generated during the attack

Aug 5, 2026 @ 17:55:26.479	WIN11-VICTIM	Process loaded taskschd.dll module. May be used to create delayed malware execution	4	92154
Aug 5, 2026 @ 17:55:26.413	WIN11-VICTIM	Executable dropped in Windows root folder	6	92217
Aug 5, 2026 @ 17:55:26.365	WIN11-VICTIM	Executable dropped in Windows root folder	6	92217
Aug 5, 2026 @ 17:55:25.478	WIN11-VICTIM	Evidence of new service creation found in registry under HKLM\System\CurrentControlSet\Services\KslD\Allo...	3	92307
Aug 5, 2026 @ 17:55:25.033	WIN11-VICTIM	Discovery activity executed	3	92031
Aug 5, 2026 @ 17:55:22.425	WIN11-VICTIM	Process loaded taskschd.dll module. May be used to create delayed malware execution	4	92154
Aug 5, 2026 @ 17:55:22.401	WIN11-VICTIM	Process loaded taskschd.dll module. May be used to create delayed malware execution	4	92154

Figure 22 – Rule match: suspicious system binary modification or execution

Document Details		View surrounding documents	View single document
Table	JSON		
index	wazuh-alerts-4.x-2026.08.05		
agent.id	001		
agent.ip	192.168.56.10		
agent.name	WIN11-VICTIM		
data.win.eventdata.creationU	2026-08-05 12:25:21.515		
data.win.eventdata.image	C:\\ProgramData\\Microsoft\\Windows Defender\\Platform\\4.18.2606.0.3008-0\\MpCmdRun.exe		
data.win.eventdata.processGu	{bc1d47ba-2bb0-6a73-8b00-00000000c00}		
data.win.eventdata.processId	5696		
data.win.eventdata.targetFil	C:\\Windows\\SystemTemp\\D5192506-F0F1-4F93-8962-951A58022473\\MpcOmmU\\UpdatePlatform.exe		
data.win.eventdata.user	NT AUTHORITY\\SYSTEM		
data.win.eventdata.utcTime	2026-08-05 12:25:21.515		
data.win.system.channel	Microsoft-Windows-Sysmon/Operational		
data.win.system.computer	WIN11-VICTIM		
data.win.system.eventID	11		

Figure 23 – Alert details: Event triggered from lock screen context

Document Details

[View surrounding documents](#)

[View single document](#)

data.win.system.task	11
data.win.system.threadID	876
data.win.system.version	2
decoder.name	windows_eventchannel
id	1785932726.1915302
input.type	log
location	EventChannel
manager.name	wazuh-server
rule.description	Executable dropped in Windows root folder
# rule.firedtimes	6
rule.groups	sysmon, sysmon_eid11_detections, windows
rule.id	92217
# rule.level	6
rule.mail	false
rule.mitre.id	T1570
rule.mitre.tactic	Lateral Movement
rule.mitre.technique	Lateral Tool Transfer
timestamp	Aug 5, 2026 @ 17:55:26.413

Figure 24 – Process tree showing cmd.exe spawned from winlogon.exe

	Aug 5, 2026 @ 17:51:59.342	WIN11-VICTIM	Explorer process was accessed by C:\\Users\\WIN11-VictimMachine\\AppData\\Local\\Microsoft\\OneDrive\\On...	12	92910
	Aug 5, 2026 @ 17:51:58.049	WIN11-VICTIM	Windows Logon Success	3	60106
	Aug 5, 2026 @ 17:51:53.154	WIN11-VICTIM	Scripting file created under Windows Temp or User folder	6	92200
	Aug 5, 2026 @ 17:51:53.112	WIN11-VICTIM	Scripting file created under Windows Temp or User folder	6	92200

Rows per page: 15

< 1 ... 28 29 **30** 31 32 ... 65 >

Figure 25 – Wazuh rule ID and description matching the attack pattern

Document Details

[View surrounding documents](#)

[View single document](#)

Table

JSON

_index	wazuh-alerts-4.x-2026.08.05
agent.id	001
agent.ip	192.168.56.10
agent.name	WIN11-VICTIM
data.win.eventdata.creationUTCtime	2026-08-05 12:21:52.342
data.win.eventdata.image	C:\\WINDOWS\\system32\\svchost.exe
data.win.eventdata.processGUID	{bc1d47ba-222a-6a73-e700-00000002b00}
data.win.eventdata.processId	5464
data.win.eventdata.ruleName	technique_id=T1574.010, technique_name=Services File Permissions Weakness
data.win.eventdata.targetFilename	C:\\Windows\\Temp\\sleep_study_top_offenders_summary.json.duplicate
data.win.eventdata.user	NT AUTHORITY\\SYSTEM
data.win.eventdata.utcTime	2026-08-05 12:21:52.342
data.win.system.channel	Microsoft-Windows-Sysmon/Operational
data.win.system.computer	WIN11-VICTIM

Figure 26 – File integrity monitoring alert on utilman.exe change

Document Details		View surrounding documents	View single document	✕
data.win.system.task	11			
data.win.system.threadID	856			
data.win.system.version	2			
decoder.name	windows_eventchannel			
id	1785932513.1731408			
input.type	log			
location	EventChannel			
manager.name	wazuh-server			
rule.description	Scripting file created under Windows Temp or User folder			
rule.firedtimes	7			
rule.groups	sysmon, sysmon_eid11_detections, windows			
rule.id	92200			
rule.level	6			
rule.mail	false			
rule.mitre.id	T1059 T1105			
rule.mitre.tactic	Execution, Command and Control			
rule.mitre.technique	Command and Scripting Interpreter, Ingress Tool Transfer			
timestamp	Aug 5, 2026 @ 17:51:53.154			

Figure 27 – Wazuh FIM detecting the rename/replace of utilman.exe

Aug 4, 2026 @ 22:08:41.857 - Aug 5, 2026 @ 22:08:41.857				
Export Formatted	783 available fields	Columns	Density	1 fields sorted
timestamp	agent.name	rule.description	rule.level	rule.id
Aug 5, 2026 @ 17:51:28.837	WIN11-VICTIM	Process loaded taskschd.dll module. May be used to create delayed malware execution	4	92154
Aug 5, 2026 @ 17:51:27.874	WIN11-VICTIM	Software protection service scheduled successfully.	3	60642
Aug 5, 2026 @ 17:51:19.536	WIN11-VICTIM	Process loaded taskschd.dll module. May be used to create delayed malware execution	4	92154
Aug 5, 2026 @ 17:50:57.833	WIN11-VICTIM	License activation (slui.exe) failed.	5	60646
Aug 5, 2026 @ 17:50:57.346	WIN11-VICTIM	Windows Logon Success	3	60106
Aug 5, 2026 @ 17:50:49.413	WIN11-VICTIM	Scripting file created under Windows Temp or User folder	6	92200
Aug 5, 2026 @ 17:50:49.291	WIN11-VICTIM	Scripting file created under Windows Temp or User folder	6	92200
Aug 5, 2026 @ 17:50:49.057	WIN11-VICTIM	Process loaded taskschd.dll module. May be used to create delayed malware execution	4	92154
Aug 5, 2026 @ 17:50:48.114	WIN11-VICTIM	Windows Logon Success	3	60106
Aug 5, 2026 @ 17:50:48.018	WIN11-VICTIM	Windows Logon Success	3	60106
Aug 5, 2026 @ 17:50:47.845	WIN11-VICTIM	Windows Logon Success	3	60106
Aug 5, 2026 @ 17:45:10.577	WIN11-VICTIM	Windows Logon Success	3	60106
Aug 5, 2026 @ 17:45:10.409	WIN11-VICTIM	Windows Logon Success	3	60106
Aug 5, 2026 @ 17:44:33.147	WIN11-VICTIM	Scripting file created under Windows Temp or User folder	6	92200
Aug 5, 2026 @ 17:43:14.733	WIN11-VICTIM	Executable dropped in Windows root folder	6	92217

Figure 28 – Full alert timeline showing attack progression

5.4 Key Wazuh Detection Rules Triggered

The following Wazuh rules are relevant to detecting this attack:

- Rule 592 / 594 — Windows File Integrity Monitoring: detects modification to system binaries in System32
- Rule 60103 / 60144 — Windows Event: Suspicious process creation from winlogon.exe context
- Rule 60290 — Accessibility feature binary replaced (utilman.exe, sethc.exe, osk.exe)
- Rule 91702 — New local administrator account created

5.5 Wazuh FIM (File Integrity Monitoring)

Wazuh's FIM module can be configured to monitor the System32 directory and alert on any changes to critical binaries. Add to ossec.conf on the agent:

```
<syscheck>
  <directories realtime="yes" report_changes="yes" check_all="yes">
    C:\Windows\System32
  </directories>
  <frequency>300</frequency>
</syscheck>
```

When utilman.exe is replaced, Wazuh FIM will generate an alert with the MD5/SHA256 hash change, file size change, and modification timestamp — creating a forensic trail.

6. Restoration — Undoing the Attack

After completing the lab, it is critical to restore the system to its original state. Failure to do so leaves a permanent SYSTEM-level backdoor on the login screen.

Step-by-Step Restoration

1. Reboot the machine and hold Shift + Restart → Enter WinRE again.
2. Open Command Prompt from Advanced Options.
3. Navigate to System32:

```
C:
cd Windows\System32
```

4. Remove the fake utilman.exe (which is actually cmd.exe) and restore the backup:

```
del utilman.exe
ren utilman1.exe utilman.exe
```

5. Verify:

```
dir utilman*
```

You should see only utilman.exe (the original). No utilman1.exe should remain.

6. Type exit and click Continue to reboot into Windows.
7. Test: Click the Ease of Access icon on the lock screen — it should open the normal Accessibility menu, not a CMD window.

If you used copy cmd.exe utilman.exe (recommended), cmd.exe is still intact in System32. If you used ren cmd.exe utilman.exe, you also need to restore cmd.exe (copy from another Windows machine or extract from the Windows installation media).

7. Defences & Hardening

7.1 Enable BitLocker Drive Encryption

This is the most effective single defence. If the drive is encrypted with BitLocker, WinRE cannot write to the Windows partition without the recovery key. Even with physical access, the attacker cannot replace utilman.exe.

```
manage-bde -on C: -recoverypassword # Enable BitLocker from admin CMD
```

7.2 Disable WinRE (Not Recommended for End Users)

WinRE can be disabled, though this also disables legitimate recovery options:

```
reagentc /disable # Disables WinRE
reagentc /info    # Check WinRE status
```

7.3 Enable UEFI Secure Boot + BIOS Password

Prevent booting from external media and restrict access to recovery options via BIOS/UEFI firmware password. This stops attackers from booting a live Linux USB to mount and modify the drive directly.

7.4 Enable Windows Defender Credential Guard

Credential Guard uses Virtualization-Based Security (VBS) to protect LSASS and credential stores, making post-exploitation harder even if an attacker gets SYSTEM.

7.5 Monitor with Wazuh FIM + SIEM Alerting

Deploy Wazuh with FIM on System32 to detect any modification to accessibility binaries (utilman.exe, sethc.exe, osk.exe, narrator.exe, magnify.exe).

7.6 Software Restriction Policies / AppLocker

Use AppLocker or Windows Defender Application Control to prevent unauthorized executables from running in SYSTEM context from the lock screen.

7.7 Defence Summary Table

Defence Measure	Effectiveness	Notes
BitLocker Encryption	Blocks Attack	WinRE cannot write to encrypted partition
Wazuh FIM on System32	Detects Attack	Post-change alert; needs monitoring
UEFI Secure Boot + BIOS Password	Partial Block	Prevents USB boot, not WinRE built-in
Disable WinRE	Partial Block	Breaks recovery capability
AppLocker / WDAC	Detects/Limits	Prevents certain post-exploitation actions
Credential Guard	Hardens Post-Exploit	Doesn't block the attack, limits damage
Network-based MFA	Compensating Control	Useful for domain accounts, not local

8. Forensic Investigation Notes

8.1 How to Detect If This Was Done on a System

If you are investigating a potentially compromised Windows machine, check the following:

Check utilman.exe Hash

Compare the hash of utilman.exe to a known-good value from a clean system:

```
Get-FileHash C:\Windows\System32\utilman.exe -Algorithm SHA256  
# Expected clean SHA256 differs by Windows version – compare with a reference
```

Check for Backup File

```
dir C:\Windows\System32\utilman1.exe  
# If this file exists, the attack was performed and not cleaned up
```

Check File Metadata

```
Get-Item C:\Windows\System32\utilman.exe | Select-Object CreationTime,  
LastWriteTime, Length  
# Compare timestamps – utilman.exe should NOT have been modified recently
```

Check Windows Event Logs

```
Get-WinEvent -LogName Security | Where-Object {$_. Id -eq 4688} | Format-List  
# Look for cmd.exe launched as utilman.exe from winlogon.exe parent
```

8.2 Persistence Analysis

Once the attacker resets the password or adds an account, additional persistence indicators may include:

- New local admin account created (check lusrmgr.msc or Event ID 4720)
- Scheduled tasks created (schtasks /query)
- Registry run keys modified (HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run)
- Remote access tools installed (check recently installed programs or netstat -an)

9. Conclusion

The Utilman.exe accessibility bypass is a classic and highly effective technique that exploits the trust placed in WinRE and pre-authentication accessibility features on Windows systems. It requires no special tools, no network access, and no knowledge of any user's password — only physical or console access and an unencrypted drive.

In a real-world attack scenario, this technique can be executed in under 5 minutes on an unprotected machine, giving an adversary complete SYSTEM-level access — the highest privilege tier in Windows.

From a Blue Team and SOC perspective, Wazuh SIEM with File Integrity Monitoring provides the best visibility into this attack — detecting the binary replacement before or when it is triggered. BitLocker remains the strongest preventative control.

9.1 Key Takeaways

- Physical access = full control on unencrypted Windows systems
- WinRE CMD runs at SYSTEM level and bypasses OS-level permission checks
- utilman.exe is called pre-authentication → perfect hijack target
- Wazuh FIM + Event Log monitoring can detect this attack
- BitLocker is the #1 defence — without it, no software-only control can fully stop this
- Always restore modified binaries after testing — leaving the backdoor open is a serious risk

9.2 Real-World Relevance

This technique is used by penetration testers, red teams, and has been observed in real APT campaigns (notably in targeted attacks against Windows workstations with physical access). It appears on the OSCP exam, CEH practicals, and is referenced in multiple SANS courses. Understanding both the attack and the detection is essential for any cybersecurity professional.

— END OF REPORT —